

Mock Internal Audit — Vantage Cloud Solutions

A self-directed GRC project simulating a multi-framework internal audit conducted ahead of a company’s first SOC 2 Type II and ISO 27001 certification cycle — the core audit methodology skill that underlies most GRC analyst roles.

Project Summary

This project conducts an internal audit of **Vantage Cloud Solutions**, a fictional B2B SaaS company pursuing dual SOC 2 Type II and ISO 27001 certification. Rather than auditing against a single framework, the project deliberately cross-maps every control to **NIST 800-53, SOC 2 Common Criteria**, and **ISO 27001 Annex A** simultaneously — reflecting how companies pursuing multiple certifications in parallel actually structure their compliance evidence to avoid duplicating work. The project follows the full internal audit lifecycle:

1. **Control selection** — sampling 15 controls across 11 categories (access control, data protection, system operations, incident response, change management, business continuity, vendor risk, risk management, people security, physical security, and configuration management)
2. **Evidence review** — assigning each control a status (Compliant, Partially Implemented, Non-Compliant, or Not Applicable) based on specific, quantified evidence rather than impressionistic judgment
3. **Severity scoring** — rating each gap Critical, High, or Medium based on how much active exposure it represents, not just whether a policy document is missing
4. **Audit reporting** — a 2-page report summarizing scope, results, findings, and lessons learned
5. **Corrective Action Plan** — a phased, owner-assigned remediation roadmap sequenced by severity and dependency

Deliverables

File	Description
Vantage_Internal_Audit_Checklist.xlsx / .pdf	Full 15-control checklist with framework cross-mapping, evidence, status, findings, severity, and remediation, plus a summary statistics tab
Vantage_Audit_Report_and_CAP.docx / .pdf	2-page audit report (scope, results, findings, lessons learned) plus a 3-phase Corrective Action Plan

What I Did

- Selected 15 controls deliberately spanning every control category that has appeared across this portfolio’s other five projects, to demonstrate breadth rather than depth in only one area

- Cross-mapped every control to three frameworks at once (NIST 800-53, SOC 2, ISO 27001 Annex A), reflecting the real-world practice of dual/multi-framework certification rather than treating each framework as a separate exercise
- Wrote evidence statements with specific, quantified findings (e.g., “3 of 6 sampled vendors,” “4 of 10 deployments,” “2 of 14 hosts”) rather than vague descriptions, since sample-based, numeric evidence is what makes an audit finding defensible
- Deliberately included one control (Physical & Environmental Access) scoped as Not Applicable, modeling a realistic audit scoping decision for a cloud-native company rather than forcing every control into the sample regardless of relevance
- Distinguished audit severity from risk severity: a finding’s severity here reflects how much active exposure or certification risk it represents right now, which is a narrower and more audit-specific question than the likelihood/impact risk scoring used in this portfolio’s risk register project
- Identified that Vantage’s strongest controls were technical (encryption, RBAC, configuration management, training) while its weakest were governance/process controls requiring cross-functional ownership (vendor risk, change approval, data classification) — and used that pattern to inform how remediation was sequenced
- Built a 3-phase Corrective Action Plan (0-30, 31-60, 61-90 days) sequenced by severity and dependency, rather than listing all 10 findings as equally urgent
- Explicitly connected one finding (F-09, untested IR plan) back to the lessons learned in this portfolio’s own Meridian Electronics incident response project, recognizing the same root-cause pattern recurring across independent work

What I Learned

- **A finding is only as strong as its evidence sample.** Writing “access wasn’t revoked timely” is an opinion. Writing “5 of 5 sampled offboarding tickets showed 3-9 day delays, with no documented SLA” is a finding an auditor can defend under challenge. The discipline of sampling and quantifying, rather than generalizing, was the single most important audit skill this project reinforced.
- **Audit severity and risk severity are related but distinct questions.** A risk register asks “how likely and how bad would this be if it happened.” An audit finding’s severity asks “how much does this threaten the certification, and how exposed are we right now.” An untested backup (contained, not currently exploited) and an absent vendor review (active, current, unassessed exposure) can both be real gaps, but they don’t deserve the same severity rating.
- **The most common real audit pattern is technical maturity outpacing governance maturity.** Encryption, access control, and configuration management are usually implemented correctly by engineers as a matter of course. Vendor risk management, data classification, and consistent change approval require a named process owner outside any one person’s default responsibilities — and that ownership gap, not technical incompetence, is where most findings in this audit actually originated.
- **“Not Applicable” is a legitimate, defensible audit outcome, not a shortcut.** Scoping a control out because it genuinely doesn’t apply (no physical infrastructure to

protect) is different from skipping a control that's inconvenient to assess. Documenting *why* something is out of scope is itself part of a credible audit.

- **A Corrective Action Plan needs sequencing logic, not just a list.** Treating all 10 findings as equally urgent would be both unrealistic and unhelpful to the people who have to execute the remediation. Phasing by severity, while accounting for which fixes are quick wins versus longer efforts, is what turns a findings list into something an organization can actually act on.

Real-World Application

Internal audits like this one are a recurring, core responsibility in GRC roles, particularly for organizations pursuing or maintaining certifications:

- **Pre-certification readiness** — companies almost universally run an internal audit before paying for an external SOC 2 or ISO 27001 audit, specifically to find and fix findings like these before an external auditor (and the company's own customers, who will eventually see the resulting report) finds them first
- **Continuous compliance maintenance** — SOC 2 Type II in particular requires controls to operate effectively over an observation period, meaning internal audits recur on a cycle (often quarterly or semi-annually) rather than happening once
- **Multi-framework efficiency** — most real companies pursuing both SOC 2 and ISO 27001 (or adding HIPAA, PCI-DSS, or FedRAMP later) build their control evidence to satisfy multiple frameworks simultaneously, exactly as modeled in this project's three-framework cross-mapping
- **Board and customer assurance** — the Corrective Action Plan format demonstrated here is what gets presented to leadership and, in redacted form, sometimes to enterprise customers who ask "what did your last audit find, and what are you doing about it" during their own vendor risk reviews — directly mirroring the vendor assessment work in this portfolio's Slack project, but from the other side of the relationship

Conclusion

This project completes the portfolio by demonstrating the audit methodology that, in many ways, validates all the other work: a control matrix, a risk register, an incident response plan, and a vendor assessment are only as credible as an independent audit confirms them to be. Conducting this audit as a standalone exercise, rather than auditing this portfolio's own prior projects, was a deliberate choice to demonstrate genuine, unbiased evaluation rather than self-grading. The resulting findings reflect a realistic, common pattern — strong technical implementation paired with under-owned governance process — and the phased Corrective Action Plan reflects the actual deliverable a GRC analyst would be expected to produce and then track to closure. Together with the other five projects in this portfolio, this audit represents the full GRC analyst skill set: building compliance programs, managing risk, assessing vendors, planning for incidents, visualizing program health, and independently verifying that all of it actually works.

This is a self-directed portfolio project using a fictional organization. It does not reflect any real company's audit results or certification status.

Internal Audit Report

Vantage Cloud Solutions | SOC 2 Type II + ISO 27001 Readiness Audit | Prepared by Kevin Liao

Audit Scope & Methodology

This internal audit evaluated 15 controls across Vantage Cloud Solutions' information security program, sampled to represent the company's full control environment ahead of its first SOC 2 Type II and ISO 27001 certification cycle. Controls were assessed against three frameworks simultaneously: NIST 800-53 (technical baseline), SOC 2 Common Criteria, and ISO 27001 Annex A, reflecting the company's pursuit of dual certification. Evidence reviewed included system configuration exports, policy documents, ticket samples, training records, and staff interviews. One control (Physical & Environmental Access) was scoped out as Not Applicable, since Vantage operates as a fully cloud-native organization with no company-controlled physical infrastructure.

Overall Results

Compliant	Partially Implemented	Non-Compliant	Not Applicable
4 of 15 (29%)	5 of 15 (36%)	5 of 15 (36%)	1 of 15

Vantage's control environment shows a clear pattern: technical controls implemented directly by engineering (encryption, role-based access, configuration management) are largely mature, while governance and process controls that require cross-functional ownership (vendor risk, change approval, data classification) are the weakest area. This is a common and recognizable pattern for a fast-growing company pursuing its first formal certification, and it directly informs how remediation should be sequenced below.

Findings Summary

Ten findings were identified, corresponding one-to-one with the ten controls rated Partially Implemented or Non-Compliant. Findings are summarized below by severity; full evidence and remediation detail for each is documented in the companion Internal Audit Checklist.

ID	Finding	Severity	Owner	Due
F-01	Third-party / vendor risk management process absent	Critical	Security/Compliance Lead	2026-08-05
F-02	No vulnerability scanning or patch SLA; end-of-support hosts in production	Critical	Engineering Lead	2026-07-05
F-03	Change management lacks consistent approval (40% of sample)	Critical	Engineering Lead	2026-07-10
F-04	Data classification scheme does not exist	High	Security/Compliance Lead	2026-08-10
F-05	Access deprovisioning not timely or SLA-bound (3-9 day delays)	High	IT Administrator	2026-07-10
F-06	MFA not enforced for all user populations (12 accounts)	High	IT Administrator	2026-07-15
F-07	No formal, documented risk assessment methodology	Medium	Security/Compliance Lead	2026-08-20
F-08	No documented security log review	Medium	Security/Compliance Lead	2026-08-01

	process			
F-09	Incident response plan untested in past 12 months	Medium	Security/Compliance Lead	2026-09-01
F-10	Backup restoration untested in past 12 months	Medium	Engineering Lead	2026-08-15

Lessons Learned

Three patterns are worth highlighting beyond the individual findings themselves. First, every Critical finding (F-01, F-02, F-03) represents an area of active, current exposure rather than a documentation gap alone — vulnerability scanning, vendor oversight, and deployment approval are all things that could be exploited or fail today, which is why they were prioritized above findings that, while real, are presently contained (such as an untested but existing backup or IR plan). Second, the audit surfaced a consistent root-cause pattern: several findings (F-04, F-07, F-08) share a common underlying cause — the absence of a named, accountable process owner for governance functions that fall outside any single engineer's day-to-day responsibilities. Third, two findings (F-09, F-10) reflect the same general lesson already learned in this auditor's prior incident response tabletop exercise work: a written plan or configured safeguard that has never been tested under realistic conditions cannot be assumed to work as intended.

Corrective Action Plan (CAP)

Remediation is sequenced in three phases based on severity and dependency, consistent with the audit's finding that Critical items represent active exposure requiring immediate attention.

Phase 1 — Immediate (0–30 days): Critical Findings

- F-02: Resume monthly vulnerability scanning; patch or decommission end-of-support hosts. Owner: Engineering Lead. Due: 2026-07-05.
- F-03: Enforce mandatory second-approver review via branch protection rules, no exceptions. Owner: Engineering Lead. Due: 2026-07-10.
- F-05: Document and implement a same-day access revocation SLA. Owner: IT Administrator. Due: 2026-07-10.
- F-06: Enforce MFA at the identity provider level for all remaining user populations. Owner: IT Administrator. Due: 2026-07-15.

Phase 2 — Near-term (31–60 days): High and Selected Medium Findings

- F-01: Establish a vendor risk assessment process and complete reviews for all critical vendors. Owner: Security/Compliance Lead. Due: 2026-08-05.
- F-04: Develop and communicate a data classification scheme. Owner: Security/Compliance Lead. Due: 2026-08-10.
- F-10: Perform and document a full backup restoration test. Owner: Engineering Lead. Due: 2026-08-15.
- F-08: Document a log review cadence and assign named alert-triage ownership. Owner: Security/Compliance Lead. Due: 2026-08-01.

Phase 3 — Medium-term (61–90 days): Remaining Medium Findings

- F-07: Formalize a documented risk register with a defined scoring methodology. Owner: Security/Compliance Lead. Due: 2026-08-20.
- F-09: Conduct a tabletop exercise and establish a recurring semi-annual testing cadence. Owner: Security/Compliance Lead. Due: 2026-09-01.

A follow-up audit reviewing all 10 findings for closure is recommended at the 90-day mark, prior to scheduling the formal external SOC 2 Type II observation period or ISO 27001 certification audit.

Vantage Cloud Solutions — Internal Audit Checklist

Scope: SOC 2 Type II + ISO 27001 (NIST 800-53 baseline) | Audit Date: 2026-06-21 | Auditor: Kevin Liao

#	Control	Category	Framework Mapping	Status	Evidence Reviewed	Finding ID	Severity	Remediation	Owner	Due Date
1	Multi-Factor Authentication Enforcement	Access Control	NIST IA-2, IA-5 SOC 2 CC6.1 ISO A.5.17, A.8.5	Partially Implemented	IAM console screenshot shows MFA enabled for all engineering staff, but sales and customer success teams (12 users) authenticate via SSO without MFA enforced at the identity provider level.	F-06	High	Enforce MFA at the identity provider level for all user populations, not just engineering.	IT Administrator	2026-07-15
2	User Access Provisioning & Deprovisioning	Access Control	NIST AC-2 SOC 2 CC6.2, CC6.3 ISO A.5.18	Non-Compliant	Offboarding ticket sample (5 of 5 reviewed) shows access revocation completed 3-9 days after termination date, not same-day; no documented SLA exists for revocation timing.	F-05	High	Document a same-day access revocation SLA and automate deprovisioning via HRIS-to-IAM integration where possible.	IT Administrator	2026-07-10
3	Least Privilege / Role-Based Access Control	Access Control	NIST AC-6 SOC 2 CC6.1, CC6.3 ISO A.8.2, A.8.3	Compliant	IAM policy export shows scoped, role-specific permissions; no standing AdministratorAccess grants found outside the two-person platform team, consistent with documented access tiers.	—	—	Maintain current practice; re-verify at next audit cycle.	Engineering Lead	—
4	Encryption of Data at Rest and in Transit	Data Protection	NIST SC-8, SC-28 SOC 2 CC6.1, CC6.7 ISO A.8.24	Compliant	Database and storage configuration confirms encryption at rest (AES-256); TLS 1.2+ enforced on all customer-facing endpoints per load balancer configuration export.	—	—	Maintain current practice; re-verify at next audit cycle.	Engineering Lead	—
5	Security Event Logging & Monitoring	System Operations	NIST AU-2, AU-6 SOC 2 CC7.1, CC7.2 ISO A.8.15, A.8.16	Partially Implemented	Centralized logging is enabled and retained for 90 days, but no documented process exists for who reviews alerts or how often; sampled week showed 0 documented alert reviews.	F-08	Medium	Document a log review cadence (e.g., weekly) and assign named ownership for alert triage.	Security/Compliance L	2026-08-01
6	Vulnerability / Patch Management	System Operations	NIST RA-5, SI-2 SOC 2 CC7.1 ISO A.8.8	Non-Compliant	Most recent vulnerability scan is 7 months old; no documented remediation SLA by severity; 2 of 14 sampled production hosts running OS versions past vendor end-of-support.	F-02	Critical	Resume monthly vulnerability scanning immediately; patch or decommission end-of-support hosts within 30 days; document a severity-based remediation SLA.	Engineering Lead	2026-07-05
7	Incident Response Plan & Testing	Incident Response	NIST IR-1, IR-4 SOC 2 CC7.3, CC7.4 ISO A.5.24, A.5.26	Partially Implemented	A written IR plan exists and was updated 4 months ago, but no tabletop exercise or simulation has been conducted in the past 12 months to validate it.	F-09	Medium	Conduct a tabletop exercise within the next quarter and establish a recurring semi-annual testing cadence.	Security/Compliance L	2026-09-01
8	Change Management Process	Change Management	NIST CM-3 SOC 2 CC8.1 ISO A.8.32	Non-Compliant	Sample of 10 production deployments shows 6 had documented peer review/approval prior to deploy; 4 were merged and deployed directly by the author with no second approver.	F-03	Critical	Enforce mandatory second-approver review via branch protection rules on the production deployment pipeline; no exceptions.	Engineering Lead	2026-07-10
9	Backup & Recovery Testing	Business Continuity	NIST CP-9, CP-10 SOC 2 CC7.5, CC9.1 ISO A.8.13	Partially Implemented	Automated daily backups confirmed via configuration export, but no restoration test has been performed or documented in the past 12 months.	F-10	Medium	Perform and document a full backup restoration test within 60 days; establish an annual recurring test requirement.	Engineering Lead	2026-08-15
10	Third-Party / Vendor Risk Management	Vendor Risk	NIST SA-9, SR-2 SOC 2 CC9.2 ISO A.5.19, A.5.20	Non-Compliant	No formal vendor risk assessment process exists; 3 of 6 sampled critical vendors (including the primary cloud hosting provider) have no documented security review on file.	F-01	Critical	Establish a vendor risk assessment process (e.g., security questionnaire + SOC 2/ISO certificate review) and complete reviews for all critical vendors within 45 days.	Security/Compliance L	2026-08-05
11	Risk Assessment Process	Risk Management	NIST RA-3 SOC 2 CC3.1, CC3.2 ISO A.5.1, Clause 6.1.2	Partially Implemented	An informal risk discussion occurs at quarterly leadership meetings, but no documented risk register, scoring methodology, or formal review cadence exists.	F-07	Medium	Formalize a documented risk register with a defined scoring methodology, reviewed at a fixed quarterly cadence.	Security/Compliance L	2026-08-20
12	Security Awareness Training	People Security	NIST AT-2 SOC 2 CC1.4, CC2.2 ISO A.6.3	Compliant	Training completion records show 100% of current staff (38 of 38) completed annual security awareness training, including phishing simulation, within the past 12 months.	—	—	Maintain current practice; re-verify at next audit cycle.	HR Lead	—
13	Data Classification & Handling	Data Protection	NIST RA-2 SOC 2 C1.1 ISO A.5.12, A.5.13	Non-Compliant	No documented data classification scheme exists; engineering and support staff confirmed in interviews they are not aware of any formal sensitivity tiers for customer data.	F-04	High	Develop a data classification scheme (e.g., Public/Internal/Confidential/Restricted) and communicate handling requirements to all staff.	Security/Compliance L	2026-08-10

Vantage Cloud Solutions — Internal Audit Checklist

Scope: SOC 2 Type II + ISO 27001 (NIST 800-53 baseline) | Audit Date: 2026-06-21 | Auditor: Kevin Liao

#	Control	Category	Framework Mapping	Status	Evidence Reviewed	Finding ID	Severity	Remediation	Owner	Due Date
14	Physical & Environmental Access Controls	Physical Security	NIST PE-3 SOC 2 CC6.4 ISO A.7.2, A.7.4	Not Applicable	Vantage is fully cloud-native with no company-controlled data center or office housing production infrastructure; scoped out of this audit cycle.	—	—	No action required; reassess applicability if physical infrastructure is introduced.	N/A	—
15	Configuration & Baseline Management	Configuration Mana	NIST CM-2, CM-6 SOC 2 CC8.1 ISO A.8.9	Compliant	Infrastructure-as-code repository confirms standardized baseline templates for all production resources; configuration drift detection tooling confirmed active via dashboard screenshot.	—	—	Maintain current practice; re-verify at next audit cycle.	Engineering Lead	—

Audit Summary Statistics

Status	Count
Compliant	4
Partially Implemented	5
Non-Compliant	5
Not Applicable	1

Severity (open findings)	Count
Critical	3
High	3
Medium	4
Low	0

Overall Compliance Rate 29%